Politica de Securitate pentru compania dezvoltatoare de jocuri video StormGuard

1 – Politica generală de securitate a informației (Policy Statement)

1.1 Cine suntem și ce protejăm

StormGuard este un studio de dezvoltare de jocuri video din București, cu 48 de angajați, care creează titluri în Unreal Engine 5 pentru PC, Xbox, PlayStation și Nintendo Switch. Valoarea companiei stă în informațiile pe care le creează și le primește în custodie: codul sursă, asset-urile artistice, audio și narative, build-urile nelansate, kit-urile de dezvoltare și documentația confidențială a producătorilor de console, datele financiare, datele angajaților și ale jucătorilor.

1.2 Scopul politicii

Scopul acestei politici este să protejeze confidențialitatea, integritatea și disponibilitatea informațiilor StormGuard și ale partenerilor săi, astfel încât:

- proprietatea intelectuală a companiei și cea primită sub NDA să nu ajungă la persoane neautorizate;
- producția jocurilor să continue chiar și după un incident major;
- StormGuard să rămână un partener de încredere pentru publisher, producătorii de console, angajați și jucători;
- obligațiile legale, contractuale și de certificare să fie respectate și demonstrabile.

Politica se aplică tuturor angajaților, stagiarilor, colaboratorilor și furnizorilor care au acces la informațiile StormGuard, tuturor sistemelor companiei (la sediu, în cloud și în regim de lucru la distanță) și dispozitivelor personale folosite pentru acces la resursele companiei.

1.3 Declarația conducerii

Conducerea StormGuard consideră securitatea informației o condiție a succesului comercial, nu doar o cerință tehnică. Prin această politică, CEO-ul se angajează să:

1. mențină și să îmbunătățească continuu un SMSI certificat ISO/IEC 27001, proporțional cu riscurile unei companii de 48 de oameni;

2. aloce resursele necesare (buget, oameni, timp de instruire) pentru atingerea obiectivelor de securitate;
3. stabilească roluri și responsabilități clare, cu un Responsabil Securitate Informație (CISO) care raportează direct CEO-ului;
4. decidă pe baza evaluării riscurilor și să aprobe personal riscurile reziduale și excepțiile;
5. respecte cerințele legale, de reglementare și contractuale aplicabile;
6. sprijine o cultură în care orice angajat raportează deschis incidentele și greșelile, fără teamă de repercusiuni pentru raportarea în sine.

1.4 Principii de Securitate

Principiu	Ce înseamnă la StormGuard
Bazat pe risc	Controalele se aleg și se dimensionează după riscul real, nu după o listă generică
Acces minim necesar	Fiecare persoană are o identitate unică și doar drepturile de care are nevoie rolul său
Securitate încă din proiectare	Securitatea și protecția datelor sunt incluse de la pre-producție, în fiecare titlu și sistem nou
Apărare în adâncime	Niciun control nu este singura barieră: identitate, dispozitive, rețea, date și oameni se protejează în straturi
Separarea atribuțiilor	Cine execută o schimbare critică nu o și aprobă; plățile au dublă autorizare
Responsabilitate individuală	Fiecare angajat răspunde de informațiile și echipamentele care i-au fost încredințate
Îmbunătățire continuă	Incidentele, auditurile și indicatorii se transformă în acțiuni de corectare

1.5 Obiective de Securitate

StormGuard urmărește șase obiective generale.

Obiectiv	Rezultatul urmărit
O1 – Protejarea proprietății intelectuale	Codul, build-urile, asset-urile și materialele NDA nelansate nu ajung la persoane neautorizate; zero scurgeri confirmate pe an

Obiectiv	Rezultatul urmărit
O2 – Acces controlat	Fiecare acces este nominal, protejat cu MFA și revizuit periodic; accesul se retrage în aceeași zi la plecare
O3 – Infrastructură rezistentă	Stațiile, serverele și rețeaua sunt actualizate, monitorizate și protejate împotriva malware-ului și a intruziunilor
O4 – Continuitatea producției	Un atac ransomware, o defecțiune sau un incident fizic nu opresc producția peste țintele RTO și nu pierd date peste țintele RPO
O5 – Personal conștient de riscuri	Angajații recunosc și raportează phishing-ul, tentativele de fraudă și incidentele
O6 – Conformitate demonstrabilă	Certificarea ISO 27001 este menținută; cerințele GDPR, financiar-contabile, ale producătorilor de console și ale licențelor sunt respectate

1.6 Indicatori KPI

Obiectiv	Indicator (KPI)	Țintă	Responsabil	Frecvență
O1	Incidente confirmate de scurgere (cod, build, asset, materiale NDA)	0 pe an	IT Lead (CISO)	Trimestrial
O1	Build-uri externe livrate cu watermark și prin canal aprobat	100%	Build Engineer / Game Master	Lunar
O1	Devkit-uri reconciliate cu registrul producătorilor	100%, fără lipsuri	IT Suport	Trimestrial
O2	Conturi cu MFA activ (Entra ID, Perforce, Jenkins, VPN, portaluri console, internet banking)	100%	IT Suport	Lunar
O2	Conturi revocate în aceeași zi lucrătoare la plecare	100%	HR + IT Suport	Lunar
O2	Revizuiri de acces finalizate la termen (Perforce, AD/Entra, Jenkins, M365, aplicații financiare)	100%	Lead-uri + IT Lead	Trimestrial
O2	Conturi administrative	3 conturi adm- nominale (unul per membru IT) + 2 de urgență; Domain/Global Admin doar IT Lead și IT Infra	IT Lead	Trimestrial

Obiectiv	Indicator (KPI)	Țintă	Responsabil	Frecvență
O3	Stații conforme (criptare, EDR activ, patch-uri la zi)	≥ 98%	IT Suport	Lunar
O3	Vulnerabilități critice remediate în 14 zile	≥ 95%	IT Infra / IT Suport	Lunar
O3	Alerte critice IDS/IPS, EDR și SIEM triate în 24 de ore	100%	Membrul IT de gardă	Lunar
O3	Programul de contabilitate la ultima versiune publicată de producător	100%, în 14 zile de la publicare	IT Infra + Financiar	Lunar
O4	Teste de restaurare reușite (Perforce, AD, Jenkins, NAS, date financiare)	100%, trimestrial	IT Infra, verificat de IT Lead	Trimestrial
O4	Joburi de backup reușite	≥ 98%	IT Infra	Săptămânal
O4	Copii backup imuabile (local hardened și offsite) verificate	100%	IT Infra	Lunar
O5	Angajați cu instruirea anuală finalizată	≥ 95%	HR + IT Lead	Trimestrial
O5	Rata de click în simulările de phishing	< 5%	IT Lead	Trimestrial
O5	Rata de raportare a e-mailurilor de phishing simulate	≥ 60%	IT Lead	Trimestrial
O5	Plăți executate cu dublă autorizare; modificări de cont bancar confirmate telefonic	100%	Financiar	Lunar
O6	Neconformități de audit închise la termen	≥ 90%	IT Lead	Semestrial
O6	Licențe software reconciliate cu utilizarea	100%	IT Suport	Semestrial
O6	Cereri GDPR ale persoanelor vizate soluționate în 30 de zile	100%	HR (persoana desemnată GDPR)	Trimestrial
O6	Incidente notificabile raportate în termenul legal	100%	IT Lead (CISO)	La eveniment

1.7 Responsabilități pe scurt

- CEO: aprobă politica, bugetul, riscurile reziduale și excepțiile; prezidează analiza de management.

- CISO (IT Manager Lead): administrează SMSI, raportează trimestrial indicatorii și coordonează răspunsul la incidente.
- Lead-urile de departament: sunt proprietarii informațiilor echipei lor; aprobă și revizuiesc accesul.
- Toți angajații și colaboratorii: respectă politicile, protejează informațiile și raportează imediat orice incident sau suspiciune.

1.8 Conformitate, excepții și revizuire

Respectarea politicii este obligatorie. Excepțiile se cer în scris, se evaluează de CISO, se aprobă de CEO și sunt valabile cel mult 12 luni. Încălcarea politicii poate atrage măsuri disciplinare conform Codului Muncii și regulamentului intern sau încetarea contractelor de colaborare. Politica se revizuiește anual și ori de câte ori se schimbă semnificativ organizația, tehnologia, legislația sau peisajul amenințărilor.

2 – Catalogul politicilor de Securitate

Politica generală se aplică prin 24 de politici specifice, grupate pe șase domenii. Fiecare politică are un proprietar, se aprobă de CEO la propunerea CISO și se detaliază, unde e nevoie, în proceduri și formulare.

Ierarhia documentelor: SG-ISMS-POL-000 (acest document) → SG-ISMS-POL-001 (politica-cadru de securitate cibernetică, v0.6, cu detaliile tehnice) → politicile specifice SG-ISMS-POL-002 … 026 → proceduri, standarde și formulare. SG-ISMS-POL-002 este deja elaborată (v0.1); codurile celorlalte sunt propuse.

2.1 Guvernanță și managementul riscurilor

Cod	Politică	Descriere scurtă	Proprietar	ISO 27001 Anexa A
POL-003	Politica de utilizare acceptabilă	Ce au voie și ce nu au voie angajații să facă cu echipamentele, conturile și informațiile companiei, inclusiv folosirea uneltelor de AI generativ, a rețelelor sociale și publicarea de work-in-progress în portofolii	CISO + HR	A.5.10
POL-004	Politica de management al riscurilor	Metodologia de evaluare (probabilitate × impact, scală 1–5), pragul de acceptare, frecvența evaluărilor și modul în care riscurile reziduale ajung la aprobarea CEO-ului	CISO	Cl. 6.1, 8.2–8.3
POL-005	Politica de clasificare și manipulare a informațiilor	Cele patru niveluri (Strict confidențial, Confidențial, Intern, Public), etichetarea în Microsoft 365 și regulile de stocare, partajare, transport și distrugere pentru fiecare nivel	CISO + proprietarii de active	A.5.12–A.5.14
POL-006	Politica de management al activelor	Inventarul stațiilor, serverelor, devkit-urilor, licențelor și conturilor cloud, cu proprietar pentru fiecare activ, returnarea la plecare și reconcilierea periodică	IT Manager – Stații și suport	A.5.9, A.5.11, A.5.32

2.2 Oameni și acces

Cod	Politică	Descriere scurtă	Proprietar	ISO 27001 Anexa A
POL-007	Politica de securitate a resurselor umane	Verificările pre-angajare, NDA și clauzele de proprietate intelectuală, instruirea la angajare și anuală, simulările de phishing, procesul disciplinar și obligațiile care continuă după plecare	HR	A.6.1–A.6.6
POL-008	Politica de control al accesului și management al identităților	Identitate unică în AD și Entra ID, MFA, reguli pentru parole, acces doar prin grupuri, conturi privilegiate separate, procesul angajare / schimbare de rol / plecare și revizuirile periodice ale drepturilor	CISO	A.5.15–A.5.18, A.8.2–A.8.5

2.3 Protecția sistemelor și a datelor

Cod	Politică	Descriere scurtă	Proprietar	ISO 27001 Anexa A
POL-002	Politica privind stațiile de lucru, endpoint-urile, lucrul la distanță, BYOD și devkit-urile	Configurația de referință a stațiilor (Intune, BitLocker, Defender), regulile de lucru de acasă și prin VPN, accesul limitat de pe telefoanele personale și evidența devkit-urilor (elaborată, v0.1)	IT Manager – Stații și suport	A.6.7, A.7.9, A.8.1, A.8.7
POL-009	Politica de securitate a rețelei	Segmentarea în VLAN-uri, regulile firewall-ului și ale IDS/IPS, accesul de la distanță prin VPN IPsec, Wi-Fi 802.1X și rețeaua de oaspeți, administrarea echipamentelor doar din rețeaua de management	IT Manager – Infrastructură	A.8.20–A.8.22
POL-010	Politica de criptografie și management al cheilor	Algoritmii și protocoalele permise, criptarea datelor în repaus și în tranzit, păstrarea, rotirea și revocarea cheilor de semnare, a certificatelor și a secretelor	CISO	A.8.24
POL-011	Politica de backup și restaurare	Schema 3-2-1-1-0, ce se salvează și cât de des, imuabilitatea copiilor, țintele RPO/RTO, retenția și testele trimestriale de restaurare	IT Manager – Infrastructură	A.8.13

Cod	Politică	Descriere scurtă	Proprietar	ISO 27001 Anexa A
POL-012	Politica de management al vulnerabilităților și al patch-urilor	Scanări lunare, termenele de remediere (critice 14 zile, ridicate 30, medii 90), actualizarea firmware-ului și a aplicațiilor, testele de penetrare anuale	IT Manager – Infrastructură	A.8.8, A.8.34
POL-013	Politica de jurnalizare și monitorizare	Ce evenimente se jurnalizează, centralizarea în SIEM, retenția de 12 luni, protecția jurnalelor administrative, sincronizarea ceasurilor și rotația de gardă pentru alerte	CISO	A.8.15–A.8.17
POL-014	Politica de management al schimbărilor și al configurației	Cum se propune, se aprobă, se testează și se documentează o schimbare de infrastructură sau de configurație de referință; separarea între cine aprobă și cine execută; monitorizarea capacității	CISO	A.8.6, A.8.9, A.8.32
POL-015	Politica de utilizare a serviciilor cloud și de prevenire a scurgerilor de date	Aprobarea serviciilor cloud noi, partajarea externă din SharePoint și OneDrive, regulile DLP și lista uneltelor de AI aprobate	CISO	A.5.23, A.8.12
POL-016	Politica de e-mail și comunicații	Protecția e-mailului (SPF, DKIM, DMARC, filtrare), canalele permise pentru materiale confidențiale (Teams, nu aplicații personale) și transferul securizat de fișiere	IT Manager – Stații și suport	A.5.14

2.4 Producție, proprietate intelectuală și parteneri

Cod	Politică	Descriere scurtă	Proprietar	ISO 27001 Anexa A
POL-017	Politica de dezvoltare securizată	Ciclul de dezvoltare după NIST SSDF: code review, fără secrete în cod, separarea stream-urilor, securizarea Jenkins, aprobarea plugin-urilor și a asset-urilor terțe, cerințele de	Lead Programmer + CISO	A.5.8, A.8.25–A.8.29, A.8.31, A.8.33

Cod	Politică	Descriere scurtă	Proprietar	ISO 27001 Anexa A
		securitate pentru componentele online ale jocurilor		
POL-018	Politica de protecție a proprietății intelectuale și a materialelor de platformă	Protecția build-urilor nelansate (watermark, canale de livrare aprobate), a SDK-urilor și a documentației NDA de la Microsoft, Sony și Nintendo, reguli pentru capturi, demo-uri și evenimente	Game Master + CISO	A.5.12, A.5.32, A.5.33
POL-019	Politica privind furnizorii și terții	Evaluarea furnizorilor înainte de contractare, clauzele de securitate obligatorii (confidențialitate, notificarea incidentelor în 24 de ore, drept de audit), relația cu publisherul și cu studiourile externe, registrul de obligații contractuale	CISO + Game Master	A.5.19–A.5.22
POL-020	Politica de securitate a operațiunilor financiare	Dubla autorizare a plăților, confirmarea telefonică a schimbărilor de cont bancar, protecția token-urilor și a certificatelor digitale, prevenirea fraudei prin e-mail (BEC)	Responsabilul Financiar + CEO	A.5.3, A.5.15

2.5 Incidente, continuitate și mediu fizic

Cod	Politică	Descriere scurtă	Proprietar	ISO 27001 Anexa A
POL-021	Politica de gestionare a incidentelor de securitate	Cum se raportează, se triează, se izolează și se închide un incident, cine decide notificarea către ANSPDCP, publisher sau producătorii de console, colectarea probelor și lecțiile învățate	CISO	A.5.5, A.5.24–A.5.28, A.6.8
POL-022	Politica de continuitate a afacerii și recuperare în caz de dezastru	Scenariile acoperite (pierderea Perforce, ransomware, căderea internetului sau a firewall-ului), prioritățile de recuperare, rolurile în criză și exercițiul anual	CISO + CEO	A.5.29, A.5.30

Cod	Politică	Descriere scurtă	Proprietar	ISO 27001 Anexa A
POL-023	Politica de securitate fizică și a mediului de lucru	Accesul pe card în sediu, camera tehnică și camera devkit-urilor, vizitatorii, CCTV, „birou curat și ecran blocat”, protecția echipamentelor și mentenanța	IT Manager – Infrastructură + Front Desk	A.7.1–A.7.14

2.6 Date personale și conformitate

Cod	Politică	Descriere scurtă	Proprietar	ISO 27001 Anexa A
POL-024	Politica de protecție a datelor cu caracter personal	Principiile GDPR aplicate angajaților, candidaților, actorilor de voce, testerilor și jucătorilor; registrul activităților de prelucrare, DPIA, cererile persoanelor vizate și notificarea încălcărilor	Persoana desemnată GDPR (HR)	A.5.34
POL-025	Politica de retenție și distrugere a informațiilor	Cât timp se păstrează fiecare categorie de informații (contabile, de personal, jurnale, build-uri), ștergerea automată și distrugerea sigură a documentelor și a mediilor de stocare	CISO + HR	A.5.33, A.7.14, A.8.10
POL-026	Politica de conformitate, audit intern și îmbunătățire continuă	Identificarea cerințelor legale și contractuale, auditul intern anual făcut de un auditor extern, analiza de management, tratarea neconformităților și registrul de excepții	CISO	A.5.31, A.5.35, A.5.36; Cl. 9–10